Ejercicio de Simulación de Crisis

Table Top Exercise (TTX) · Ransomware · Spear Phishing · Blind Eagle APT

Preparado para **Seguros Alfa** — Gerencia de Riesgos y Tecnología · Colombia 2025

CONFIDENCIAL

VERSIÓN 1.0

¿Por qué Seguros Alfa necesita este ejercicio?

El grupo **Blind Eagle (APT-C-36)** opera activamente en Colombia, suplantando entidades como la **DIAN** y la **Superintendencia Financiera** para comprometer perfiles con acceso privilegiado: gerentes de riesgo, directores de cumplimiento y analistas de tesorería.

Activos en riesgo

Bases de datos de asegurados, sistemas de siniestros y flujos de pago.

Vector silencioso

Un correo falso de la SFC puede comprometer credenciales sin alertas durante semanas.

Impacto financiero

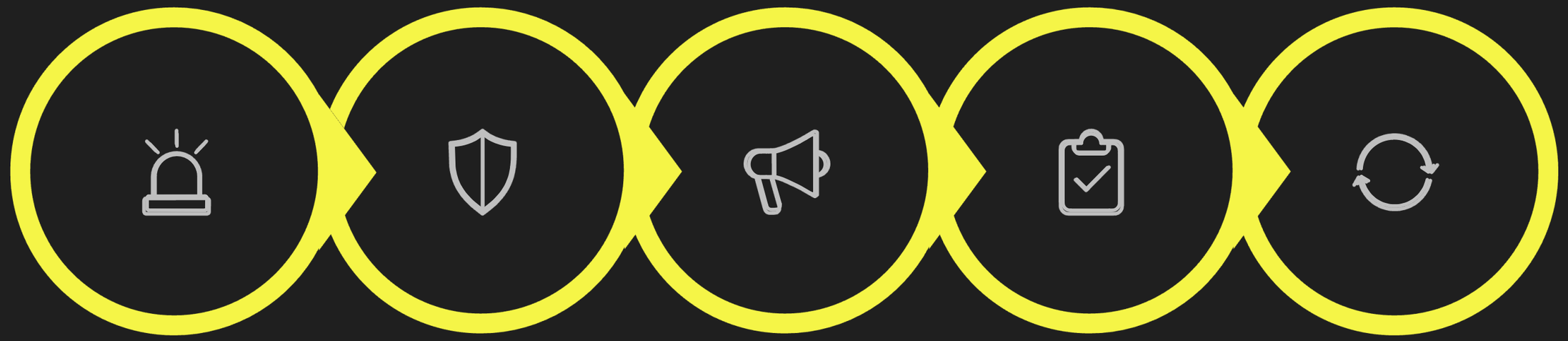
Pérdidas promedio superiores a **USD 2.8M** por incidente en el sector financiero colombiano.

67% de organizaciones financieras en Latinoamérica que sufrieron ransomware en 2024 no tenían un plan de respuesta validado.

Un Table Top Exercise corrige esa brecha **antes de que sea demasiado tarde.**

Arquitectura del Ejercicio TTX

Diseñado bajo el estándar **NIST CSF 2.0** e integrado con la matriz **MITRE ATT&CK**, el ejercicio se desarrolla en tres fases progresivas que elevan gradualmente la presión sobre el equipo directivo.



Detección Contención Comunicación Gestión Recuperación

Duración total: **4.5 horas** · Incluye briefing inicial (15 min) + debriefing ejecutivo (30 min).

Las Tres Fases en Detalle

Fase 1 · Detección & Contención

Infiltración silenciosa. El equipo identifica el vector Spear Phishing, contiene el movimiento lateral y decide si aislar sistemas críticos.

- ¿Cuándo se activa el Comité de Crisis?
- ¿Qué sistemas se aíslan y bajo qué criterio?

Fase 2 · Comunicación & Crisis

El ransomware cifra servidores de siniestros. Llega una nota de rescate. La SFC solicita información. Dilemas éticos, legales y reputacionales en simultáneo.

- ¿Se paga el rescate? ¿Quién autoriza?
- ¿Cuándo y cómo se notifica a la SFC?

Fase 3 · Continuidad & Recuperación

Activación del BCP/DRP. El equipo prioriza restauración de servicios, gestiona proveedores afectados y proyecta el impacto financiero total.

- ¿En qué orden se restauran los sistemas?
- ¿Cómo se gestiona a los reaseguradores?

Perfiles Directivos del Ejercicio

Cada rol recibe un **brief personalizado** con dilemas adaptados a su función. El lenguaje se adapta al perfil de negocio, no al técnico.

CEO / CFO

Escalar la crisis, autorizar pago de rescate, gestionar impacto económico y reaseguradores.

Legal / Compliance

Notificación a la SFC, riesgo regulatorio, SARLAFT y decisión legal sobre el rescate.

Comunicaciones

Gestión de medios, comunicación a clientes afectados y protección reputacional.

Riesgos / CISO

Activación BCP/DRP, aislamiento de sistemas, coordinación técnica y reporte al Comité de Crisis.

Lo que Obtiene Seguros Alfa

1

Validar BCP/DRP

Verificar la efectividad real del plan de continuidad y recuperación ante desastres.

2

Brechas directivas

Identificar fallas en la toma de decisiones bajo presión del equipo directivo.

3

Cumplimiento SFC

Verificar protocolos de notificación a la SFC e Instrucción SARLAFT.

4

Madurez NIST CSF 2.0

Generar métricas de madurez y construir memoria muscular para crisis reales.

Entregables Incluidos

Informe Ejecutivo

15–20 páginas con hallazgos, brechas y recomendaciones. Listo para Junta Directiva.

Mapa de Calor

Brechas mapeadas contra los 5 dominios del NIST CSF: Identificar, Proteger, Detectar, Responder, Recuperar.

Plan de Acción (PAC)

15–20 acciones concretas con responsables, plazos y priorización por riesgo regulatorio.

TTX Playbook

Guion maestro reutilizable con injects, roles, tiempos y métricas de evaluación.

Dashboard de Madurez

Scorecard por rol: tiempo de respuesta, calidad de decisión, coordinación y comunicación.

Inversión & ROI

Valor Total del Servicio

$15.000.000 COP

IVA no incluido

El costo promedio de un incidente de ransomware en el sector financiero colombiano supera los **USD 280.000** en recuperación, multas y pérdida de clientes.

Este ejercicio representa menos del 0.5% de ese costo.

¿Qué incluye?

- Diseño y personalización del escenario TTX
- Facilitación del ejercicio (4.5 horas)
- Briefings individuales por rol
- Informe ejecutivo + Mapa de calor + PAC
- TTX Playbook reutilizable
- Dashboard de métricas de madurez
- 1 sesión de seguimiento a los 30 días

ROI del Ejercicio

→ Reducción del tiempo de respuesta a incidentes

→ Cumplimiento regulatorio SFC demostrable

→ Reducción de primas de ciber-seguro

¿Listos para Comenzar?

Contáctenos para coordinar la sesión de kick-off y personalización del escenario para Seguros Alfa.

Contexto 100% colombiano

Escenarios con amenazas reales: Blind Eagle, DIAN falsa, SFC falsa.

+80 TTX facilitados

Experiencia en sectores regulados. Lenguaje adaptado a Junta Directiva y equipo técnico.

Frameworks aplicados

NIST CSF 2.0 · MITRE ATT&CK · ISO 27001 · CIS Controls v8 · SARLAFT / SFC

dagon8523@gmail.com · +57 305 7896246 · *Confidencial — Elaborado exclusivamente para Seguros Alfa · 2025*